

Elevation of Autonomy

A card-based threat modelling deck for AI, LLM and agentic systems

Version 0.1 — play-test release

About this deck

Elevation of Autonomy extends the card-based threat modelling tradition of Adam Shostack's *Elevation of Privilege* (EoP) and F-Secure's *Elevation of Privacy* into the AI and agentic space. It is designed to be played alongside either of those decks, or on its own when the system under review is primarily AI-powered.

The deck exists because the threats facing AI systems are genuinely novel — prompt injection has no direct equivalent in STRIDE, memory poisoning has no direct equivalent in LINDDUN, and context rot has no equivalent anywhere. Teams need a vocabulary for these threats and a structured way to surface them in design reviews. Cards work because they force participation: every player must play something on every trick, which is a deliberate ergonomic choice that pulls threats out of quieter voices in the room.

This is version 0.1 and I am releasing it as a play-test draft. Feedback welcome; the cards that do not work after a few sessions will be pruned and replaced.

Credits. Elevation of Autonomy extends the card-based threat modelling tradition of Adam Shostack's *Elevation of Privilege* (EoP) and F-Secure's *Elevation of Privacy* into the AI and agentic space. Full credits and acknowledgements — for the card tradition, the research foundations, and the practitioner community — appear at the end of this document.

Deck composition

30 cards across 5 suits:

- ♠ **Spades — Adversarial Threats** (6 cards, A K Q J 10 9)
- ♥ **Hearts — Autonomy Threats** (6 cards, A K Q J 10 9)
- ♦ **Diamonds — Data Threats** (6 cards, A K Q J 10 9)
- ♣ **Clubs — Privacy Threats** (5 cards, A K Q J 10)
- ★ **Trumps — Structural Hazards** (7 cards, numbered 1–7)

High cards within a suit indicate broader or more foundational threats; lower cards indicate more specific or variant threats. Trumps beat any non-trump card of any rank.

Game rules (short form)

The rules follow EoP closely. If you have played EoP, you can play this immediately.

Setup

- 3 to 6 players. Best with 4.
- Deal all 30 cards as evenly as possible. With 4 players, two get 8 cards and two get 7; the extra cards go to whoever is leading the session.
- The system being threat modelled is on a whiteboard or screen visible to all players. Ideally a data flow diagram with trust boundaries.
- Have the post-session template (or any threat register) open and a scribe nominated.

Play

1. **The player to the left of the dealer leads** by playing any card and describing how the threat on that card applies to the system being reviewed. The description must be specific — a generic "an attacker could..." does not count. If the player cannot describe a concrete application, they play a different card.
2. **Play proceeds clockwise.** Each subsequent player must either:
 - Play a card of the same suit with a more concrete or more severe application of that suit's category, OR
 - Play a trump card with a structural hazard that applies to the same component, OR
 - Pass and discard a card face-up (only if they genuinely have no applicable card in hand).
3. **Highest card wins the trick** (trumps beat all non-trump cards). The winner of the trick leads the next one.
4. **Each accepted threat is recorded** in the threat register with the card ID, the system component affected, and the specific example given. A proposed mitigation is agreed before the next trick is led.
5. **Play continues until all cards are played** or the facilitator calls the session. Whoever has surfaced the most unique, accepted threats is the winner of the game — but the real winner is the design that ships safer.

House rules worth considering

- **The Spotlight rule.** On any turn, any player may call "Spotlight" and nominate a specific component of the DFD. All players must then play a card that applies to that component or pass. Useful for forcing attention on a neglected area.
- **The Architect's Veto.** The architect in the room may veto a threat if they can demonstrate that a specific existing control eliminates it. The demonstration must be specific; "we have a WAF" does not count.
- **The Privacy Round.** If personal data is in scope, dedicate one full round to Clubs only. Forces the team to walk the T.R.I.M. categories explicitly.

The cards

Each card entry below contains:

- **Card ID and title.**
- **Quoted tagline** — read aloud when the card is played.
- **Threat description** — one paragraph, abstract.

- **References** — OWASP, LINDDUN, T.R.I.M., CAPEC mappings for post-session documentation.
- **Mitigation prompts** — not an exhaustive list, but enough to anchor the discussion.

A print-and-play PDF will follow in a later version. For now, cards are listed in text form, one per section, sized for printing on A6 index cards or for display in a digital Kanban tool.

♠ Spades — Adversarial Threats

♠A — Prompt Injection

"Anything the model reads can be interpreted as an instruction."

Threat. An attacker-controlled text reaches the model's context and is interpreted as a new instruction. The injection may be direct (in the user prompt) or indirect (in retrieved content, tool output, memory, or another agent's message). The model cannot reliably distinguish instructions from data.

References. OWASP LLM01. ASI01 when it redirects an agent. CAPEC-242 conceptually.

Mitigation prompts. How are inputs from each source delimited? What happens when a retrieved document contains an instruction? What actions are irreversible, and are any of them reachable from a single model output?

♠K — Tool Misuse

"A legitimate tool used for illegitimate ends is still destructive."

Threat. The agent invokes a legitimate, authorised tool in a way that causes harm because the arguments were attacker-influenced or the tool's blast radius was too wide.

References. ASI02. OWASP LLM06 secondary.

Mitigation prompts. For each tool, what is the worst thing it could do with attacker-controlled arguments? Are destructive arguments allow-listed? Is human confirmation required for irreversible outcomes?

♠Q — Supply Chain Compromise

"The code you didn't write runs with the credentials you have."

Threat. A component in the AI supply chain — base model, adapter, library, MCP server, prompt template — is compromised upstream or via an update.

References. OWASP LLM03. ASI04.

Mitigation prompts. What is in your AI-BOM? How are updates reviewed? What does each component have access to that it does not need?

♠J — Memory Poisoning

"Today's lie becomes tomorrow's ground truth."

Threat. An adversary causes false or malicious content to be written to long-term memory where it persists across sessions and is later retrieved as trusted context.

References. ASI06.

Mitigation prompts. Who can write to memory? Is provenance attached? Is memory partitioned per user? How are security-relevant memory reads validated?

♠10 — Improper Output Handling

"The model's output is not user input, except in every way that matters."

Threat. A downstream consumer treats model output as trusted, leading to exfiltration, rendering, or execution of attacker-influenced content.

References. OWASP LLM05.

Mitigation prompts. Which consumers of model output exist, and what do they assume? Where is output sanitised, encoded, or structured? Are there rendering paths that fetch remote content?

♠9 — Tool Description Injection

"The tool description is itself a prompt."

Threat. An MCP server (or equivalent tool registry) supplies tool descriptions and parameter schemas that arrive in the model's context as instructions. A hostile or compromised server can inject prompts via the description field itself — not just the tool's return value. The "rug pull" variant mutates the description after the user has approved the tool, so the approved version and the live version diverge silently.

References. OWASP LLM01 indirect injection. ASI01. ASI04. MCP-specific.

Mitigation prompts. Are tool descriptions pinned and integrity-checked between approval and use? What happens when a server updates a description silently? Are descriptions delimited from user prompts in the model's context? Does any tool have a description that contains imperative language?

♥ Hearts — Autonomy Threats

♥A — Excessive Agency

"Give the agent only what the task requires, then give it less."

Threat. The agent holds capabilities, permissions, or autonomy beyond what the task requires, expanding blast radius on any compromise.

References. OWASP LLM06.

Mitigation prompts. What is the minimum scope for each tool? Does the agent need autonomy, or would confirmation suffice? Could capabilities be split per task?

♥K — Identity and Privilege Abuse

"A shared service account is a shared single point of failure."

Threat. Agents share credentials, inherit broad identities, or operate with long-lived tokens. Compromise propagates across the system.

References. ASI03.

Mitigation prompts. How many agents share identities? How are credentials scoped, rotated, and audited? What is the blast radius of each identity?

♥Q — Inter-Agent Trust Exploitation

"Agents trust each other because you told them to."

Threat. An orchestrator or peer agent trusts another agent's messages, tool calls, or return values without validation. A compromised or misbehaving agent propagates its effects.

References. ASI07.

Mitigation prompts. Do agents authenticate to each other? Are inter-agent messages structured and validated? Could a rogue agent impersonate another?

♥J — Cascading Failure

"One agent's hallucination is another agent's ground truth."

Threat. An error, hallucination, or partial compromise in one agent propagates through a multi-agent system, amplifying as it spreads.

References. ASI08.

Mitigation prompts. Where are the circuit breakers? Are retry budgets bounded? Can the chain be killed from one place?

♥10 — Rogue Agent

"The agent looked legitimate in every individual action."

Threat. A compromised, misaligned, forgotten, or unsanctioned agent operates in the environment, producing harm through actions that look legitimate in isolation.

References. ASI10.

Mitigation prompts. Is there an agent inventory? How is anomalous behaviour detected? What is the kill-switch latency?

♥9 — Confused Deputy Across Servers

"Two MCP servers in one client share a context they should not share."

Threat. An MCP client is connected to multiple servers concurrently. One server's tool can shadow another's by exposing a tool with the same or similar name, intercepting calls intended elsewhere. One server can read context, approvals, or tool results that belong to another. The client becomes a confused deputy, brokering authority between mutually distrusting servers.

References. ASI03 cross-context. ASI07 inter-component trust. CAPEC-141.

Mitigation prompts. Are tools namespaced per server? Can two servers register the same tool name? Is each server's context isolated from the others? Does the user see which server a tool call is going to, in language they can verify? What happens when servers are added or removed mid-session?

◆ Diamonds — Data Threats

◆A — Sensitive Information Disclosure

"The model will tell you what it knows, whether it should or not."

Threat. The model emits personal data, secrets, or proprietary information drawn from training, retrieval, or context.

References. OWASP LLM02.

Mitigation prompts. What data is in scope for retrieval? Is authorisation enforced at the data layer? What are the output filters catching?

◆K — Vector and Embedding Weakness

"The vector store is your new database and it has no access control."

Threat. The RAG pipeline leaks data across tenants, allows embedding-based attacks, or inherits UI-layer access controls that do not apply at retrieval.

References. OWASP LLM08.

Mitigation prompts. How is the vector store partitioned? When is authorisation evaluated — at query time or earlier? Who can write to the corpus?

♦Q — Hallucinated Facts

"The model is confidently wrong and the system treats confidence as correctness."

Threat. The model generates false but plausible content that downstream consumers or users treat as ground truth. Includes slopsquatting, fabricated citations, and invented identifiers.

References. OWASP LLM09.

Mitigation prompts. Where does model output inform decisions or actions? Is there grounding? Are claims about external entities (people, packages, systems) verified?

♦J — Unbounded Consumption

"Denial of wallet is a denial of service."

Threat. Cost, compute, or rate limits are absent or ineffective. Malicious users — or bugs — cause runaway spend.

References. OWASP LLM10.

Mitigation prompts. What are the hard caps per user, per session, per agent? Are loops bounded? How is spend monitored?

♦10 — System Prompt Leakage

"The system prompt is not a secret store."

Threat. System prompts containing credentials, business logic, or security instructions are extracted via prompt injection or inference.

References. OWASP LLM07.

Mitigation prompts. What is in the system prompt that should not be? What happens if the whole prompt leaks tomorrow?

♦9 — Server Impersonation and Rogue Servers

"Every byte of your prompt and every tool result flows through that server."

Threat. An MCP server is typosquatted, hijacked, or stood up adversarially in a registry the client trusts. Once connected, it sees every prompt routed to its tools, every credential or token shared with it, and every return value. Data exfiltration is the primary risk; tool-output tampering is the secondary risk. The transport (stdio vs HTTP) changes the attack surface but not the underlying problem.

References. OWASP LLM03 supply chain. ASI04. MCP-specific.

Mitigation prompts. How is the server identified — by name, by signature, by pinned hash? What is the source of truth for the registry? What credentials and data does each server see? Is HTTP transport authenticated and bound to a specific origin? What happens if a server is silently replaced?

♣ Clubs — Privacy Threats

♣A — Transfer

"The model creates personal data at the point of transfer."

Threat. The model manufactures personal data that is then transferred to a downstream system, log, or onward recipient. The data has no provenance and no consent chain.

References. T.R.I.M. Transfer. GDPR Article 5(1)(a), 5(1)(b).

Mitigation prompts. Does the data carry provenance tags? Can downstream consumers distinguish generated from collected data? Is onward transfer logged?

♣K — Retention and Removal

"Fabricated data persists the same as real data."

Threat. Personal data — real or hallucinated — is persisted in RAG, memory, logs, or fine-tuning datasets without a mechanism for surgical removal. Article 16 and Article 17 rights become unenforceable.

References. T.R.I.M. Retention. GDPR Articles 16, 17.

Mitigation prompts. For each persistent store: can you locate a specific individual's data? Can you delete it? Can you prevent recurrence?

♣Q — Inference

"The model derives personal data you never collected."

Threat. The model infers new personal data — including special-category data under Article 9 — from partial or unrelated inputs. The act of inference is itself the privacy event.

References. T.R.I.M. Inference. GDPR Article 9. LINDDUN Identifying.

Mitigation prompts. What does the model infer about people that it was not told? Does it ever touch special categories? What is the lawful basis for inferred data?

♣J — Minimisation

"You minimise what you collect. Now minimise what you generate."

Threat. The model generates more personal data than the task requires, producing unrequested claims that are both unminimised and hallucination-prone.

References. T.R.I.M. Minimisation. GDPR Article 5(1)(c).

Mitigation prompts. Is the input minimal for the task? Is the output minimal? Are output schemas constrained to what was asked?

♣10 — Unintervenability

"The subject cannot find out, cannot correct, cannot prevent recurrence."

Threat. Data subjects have no practical mechanism to discover what the system claims about them, no route to correct it, and no assurance that corrections persist.

References. LINDDUN Unawareness/Unintervenability. GDPR Articles 13, 14, 16.

Mitigation prompts. Is the processing disclosed in the privacy notice? Is there a subject access process that covers model outputs? Do rectifications persist across sessions?

★ Trumps — Structural Hazards

Trumps beat any non-trump card. They represent structural properties of AI systems — architectural, mathematical, or product-design failures — that cannot be mitigated inside the model itself. The OWASP lists do not catch them because the OWASP framing assumes the model's behaviour is itself the defence; these cards exist because, for this class of threat, it cannot be.

★7 — Adversarial Subspace

"The attack surface is a space, not a list."

Threat. Any input to an AI system is translated into a lower-dimensional numerical representation. That flattening creates a subspace of inputs that all produce approximately the same model behaviour. The subspace is mathematically enormous, provably unsearchable, and unpatchable — it is a property of the architecture, not a bug.

Prompt-library-based red teaming and pattern-matching guardrails test a vanishing fraction of this surface. This card represents the deepest reason structural mitigations beat statistical ones.

References. Cox & Bunzel (2025), arXiv:2511.05102. Tramèr et al. (2017). Goodfellow, Shlens, Szegedy (2015). EchoGram (HiddenLayer, 2025) as a contemporary surface example.

Mitigation prompts. Are we relying on a library of known bad prompts as a defence? If yes, we are defending a vanishing fraction of the space. Is our security guarantee architectural or statistical? If statistical, what happens when the next perturbation lands outside our library tomorrow? What determines the outcome of every consequential decision — the model's classification, or a deterministic check downstream?

★6 — Geometric Attack

"The boundary is the attack surface, not the inputs that cross it."

Threat. An attacker targets the geometry of the model's decision surface directly — by probing a black-box classifier (GeoDA, SurFree), by exploiting non-Euclidean embeddings (AGSM), or by rotating an angular-margin embedding on a hypersphere (ArcFace-style attacks). The attack succeeds without access to weights, training data, or gradients.

References. Tramèr et al. 2017 foundation. GeoDA, SurFree, AGSM, angular-margin attack literature. CAPEC-115 when authentication is gated by the model.

Mitigation prompts. Does any consequential decision depend on a single model's classification? Can an attacker probe it with queries? Is the downstream enforcement deterministic or does it inherit the model's verdict? Is adversarial testing matched to the geometry the model uses?

★5 — Context Rot

"Your safety instructions were at the top. They have decayed in attention weight."

Threat. As a session grows, attention to system prompts, role definitions, and authorisation context decays. Guardrails that held on turn 1 fail on turn 50 without any adversarial input.

References. Chroma 2025 research. Cross-cutting amplifier for LLM01, LLM06, ASI01, ASI02, ASI06, ASI08.

Mitigation prompts. What is the longest realistic session? At that length, which safety-relevant tokens are in the lost-in-the-middle zone? Are critical instructions periodically re-injected?

★4 — Decision Boundary Transfer

"The boundary your model defends is the boundary every other model defends."

Threat. Models trained on the same domain share similar decision boundaries regardless of algorithm or dataset. Adversarial examples transfer freely; model robustness is a property of the domain, not the model.

References. Tramèr et al. 2017. Cox applications.

Mitigation prompts. What security guarantees are we relying on the model itself to provide? Can any of them be moved to a deterministic layer?

★3 — Excessive Autonomy by Design

"You gave the agent autonomy because the demo was cool."

Threat. Product decisions grant the agent autonomy that the risk model does not justify. Confirmation steps are removed because they are "friction". The autonomy becomes the blast radius.

References. LLM06 taken seriously at the product level.

Mitigation prompts. Which confirmations were removed for UX reasons? What is the worst thing the agent can do with no human in the loop? Does the product justification survive a post-incident review?

★2 — Invisible Dependency

"The thing you depend on is not in your SBOM."

Threat. The agent's behaviour depends on model versions, prompt templates, tool descriptions, or memory state that are not in any tracked inventory.

References. LLM03. ASI04.

Mitigation prompts. What determines this agent's behaviour? Is all of it pinned, versioned, and inventoried? What happens when an external dependency changes silently?

★1 — Wrong Abstraction

"You are treating the model as a system of record."

Threat. Downstream processes, users, or agents treat model output as authoritative. The model is neither a database nor a source of truth, and any consumer that treats it as one imports every failure mode as a fact.

References. ASI09. LLM09 at the architectural level.

Mitigation prompts. Where is model output treated as authoritative? What provenance does the UI surface? Is there a verification step, or has the caveat been lost?

Facilitator's notes

Running a first session

- Read the game rules aloud before dealing. Even experienced EoP players benefit from a refresher because the trump structure differs.
- Aim for 90 minutes including setup. Longer sessions tire players and reduce the quality of threat descriptions.
- The scribe's job is critical. Without good notes, the session produces no artefact. Use the post-session template.
- If a card cannot be applied, the player should say so and pass. Forced application produces low-quality threats and demoralises the group.

What to do between sessions

- Record which cards produced good threats and which did not. After three to five sessions, some cards will stand out as over- or under-powered. Prune the deck accordingly and submit feedback upstream.
- If your system has recurring characteristics — for example, multiple MCP servers or complex multi-agent orchestration — consider building local custom cards for the patterns that matter most to your environment.
- The deck is intentionally small. Thirty cards is fewer than EoP's seventy-four. This is deliberate: the AI threat surface is less mature and the abstractions are still being refined. A smaller deck plays faster and is easier to iterate.
- If your team repeatedly plays trumps (especially Trump 6 and Trump 7) against the same system component, that component is architecturally mis-placed. A single component drawing geometric attack and subspace cards on every pass is a component where the model is carrying a security guarantee it cannot carry. Escalate to the architect.
- The 9-rank cards in Spades, Hearts, and Diamonds (Tool Description Injection, Confused Deputy Across Servers, Server Impersonation) target the MCP threat surface specifically. If your system uses MCP — and increasingly, most agentic systems do — make sure the team has read those three cards before the session starts. They are harder to apply cold than the other cards because the threat surface is newer and the vocabulary is less settled. A two-minute walk-through at the top of the session pays back.
- If your system uses MCP but the 9-rank cards are not being played, that is itself a red flag. Either the DFD has collapsed the MCP servers into a single opaque box (open it), or the team has not internalised that tool descriptions, server registries, and cross-server contexts are all attack surfaces. Consider calling Spotlight (see house rules) on each MCP server in turn.

Feedback

This is version 0.1. Feedback — which cards work, which do not, which are missing, which are duplicative — is welcome via the usual channels. The next revision will incorporate play-test data from at least five sessions across different system types.

Credits

Elevation of Autonomy builds on work by many people, and I want to credit them clearly.

The card-based threat modelling tradition. Adam Shostack's *Elevation of Privilege* is the foundation on which this deck and its predecessors stand. The core mechanics — suit-based threats, trick-taking gameplay, trumps — are his design, released under CC BY 3.0. If you have not played EoP, the card format will make more sense after you do. F-Secure's *Elevation of Privacy* extended the tradition to privacy threats and contributed the T.R.I.M. categories that form

the Clubs suit of this deck. Both decks are prerequisites in spirit for this one, and both authors deserve recognition before anyone else.

The threat taxonomies. The OWASP GenAI Security Project produced the OWASP Top 10 for LLM Applications (2025) and the OWASP Top 10 for Agentic Applications (2026), which together form the backbone of the Spades, Hearts, and Diamonds suits. Over 100 contributors across those two lists have given the practitioner community a shared vocabulary that did not exist two years ago.

Special acknowledgement — Disesdi Shoshana Cox. One contributor deserves more than a line in a list. Cox's peer-reviewed research — particularly Cox and Bunzel (2025) on quantifying black-box transferability, and the US patent with Esra (2024) on federated model security architecture — is the empirical and architectural backbone for the Trumps suit, especially the cards on Geometric Attack (Trump 6) and Adversarial Subspace (Trump 7). Her practitioner writing at *Angles of Attack* — particularly the November 2025 piece on the subspace problem and the *How To Steal A Model* essay — translates the research into language engineers can act on, and shaped the framing of design-time structural mitigation as the primary defence that runs through every suit of this deck. The deck would be less useful, and substantially less honest, without her work.

Foundational adversarial ML research. Goodfellow, Shlens, and Szegedy (2015) for "Explaining and Harnessing Adversarial Examples". Tramèr, Papernot, Goodfellow, Boneh, and McDaniel (2017) for "The Space of Transferable Adversarial Examples". Madry, Makelov, Schmidt, Tsipras, and Vladu (2017) for "Towards Deep Learning Models Resistant to Adversarial Attacks" and the PGD attack. Guo, Gong, Lin, Yang, and Zhang (2024) for "Adversarial Hypervolume". These papers shaped the conceptual content of several cards, particularly in the Trumps suit.

Structural hazards research. Chroma Research (Hong, Troynikov, Huber, 2025) for the "Context Rot" study that forms the basis of Trump 5. Liu et al. (2023) on lost-in-the-middle effects. Both underlie the Context Rot card. The broader "structural over statistical" framing owes to the Cox and Bunzel (2025) work on transferability and subspace quantification, which anchors Trumps 6 and 7.

Geometric adversarial attacks. Rahmati et al. (2020) for GeoDA. Maho, Furon, and Le Merrer (2021) for SurFree. Jo, Kim, and Park (2025) for the Angular Gradient Sign Method. Deng et al. (2019) for ArcFace and the angular-margin tradition. These inform Trump 6.

Privacy frameworks. LINDDUN from the DistriNet research group at KU Leuven. T.R.I.M. via F-Secure's Elevation of Privacy deck. The EDPB and noyb (Max Schrems) whose ongoing GDPR casework against hallucinating LLMs has clarified the Article 16 and 17 obligations underlying the Clubs suit.

The wider community. Palo Alto Unit 42 for Agent Session Smuggling research. HiddenLayer for the EchoGram disclosure. The teams at Koi.ai, Astrix, Aembit, HUMAN Security, and Invicti whose analyses of the Agentic Top 10 in the weeks following its release informed several card entries.

If I have omitted anyone whose work shaped a specific card, please reach out — the intent is for the next version of this document to credit generously, not sparingly.

License

This deck is released under Creative Commons Attribution-ShareAlike 4.0, consistent with the licensing of *Elevation of Privilege* and *Elevation of Privacy*. You are free to print, adapt, remix, and distribute, with attribution and under the same

license.

Happy threat modelling.

Tags: threat-modelling, elevation-of-autonomy, AI-security, LLM, agentic-AI, card-game, print-and-play